

Software Requirements Specification

Zero Trust Enterprise Access Portal

Risk adaptive identity device and policy based enterprise access control

Document control	Value
Document ID	ZTAP SRS 001
Version	1.0
Status	Baseline for implementation and Scrum planning
Prepared for	Academic software engineering evaluation
Prepared on	8 October 2026
System baseline	Next.js 14 TypeScript Prisma PostgreSQL implementation in the project repository

Purpose

This specification defines the behavior, security controls, interfaces, data model, quality attributes and acceptance basis for the Zero Trust Enterprise Access Portal. It is the authoritative source for backlog refinement, verification and academic assessment.

Document control

Version	Date	Change	Owner
1.0	8 Oct 2026	Initial repository-aligned SRS baseline	Project team

Contents

- 1 Introduction
- 2 Overall description
- 3 Stakeholders and user classes
- 4 Functional requirements
- 5 External interface requirements
- 6 Data requirements
- 7 Architecture and design views
- 8 Nonfunctional requirements
- 9 Security and privacy requirements
- 10 Verification and acceptance
- 11 Requirements traceability
- 12 Constraints assumptions and risks
- 13 Glossary

1 Introduction

1.1 Purpose

ZTAP controls access to registered enterprise applications by evaluating identity, server-side roles, device posture, resource sensitivity, policy constraints, time context and an explainable risk score on every request. The system records the resulting decision and security-relevant activity for audit and review.

1.2 Scope

- Authenticate users and maintain protected server-side sessions.
- Apply least-privilege role-based authorization at API boundaries.
- Register users, roles, permissions, devices, protected resources and resource policies.
- Evaluate access requests using deterministic policy and explainable risk engines.
- Route approval-required requests to resource owners and prohibit self-approval.
- Provide employee, administrator, resource-owner and auditor dashboards.
- Maintain an append-only audit trail and provide structured SIEM-oriented export.
- Support containerized deployment and automated unit, integration, fuzz and end-to-end testing.

1.3 Out of scope

The baseline does not provide a production identity-provider federation, hardware-backed device attestation, a full SIEM product, automated provisioning into third-party applications, or a mobile client. These are future integrations, not implied current behavior.

1.4 Product objective

The primary objective is to demonstrate that access is never granted only because a user reached the portal. Each access request must be independently authenticated, authorized, risk assessed, policy evaluated, decided and logged.

2 Overall description

2.1 Product perspective

ZTAP is a full-stack web application built with the Next.js App Router and TypeScript. Browser dashboards call protected route handlers. Middleware validates an encrypted session and roles before domain services access PostgreSQL through Prisma. The policy and risk engines return deterministic decisions and evidence used by access-request, approval and audit services.

2.2 Operating environment

Area	Baseline
Client	Modern browser with JavaScript and secure cookie support
Application runtime	Node.js 20 with Next.js 14
Database	PostgreSQL 16 accessed through Prisma ORM
Local deployment	npm or Docker Compose
Orchestration	Kubernetes manifests for the ztap-system namespace
Testing	Vitest and Playwright

2.3 Product capabilities

Capability	Implemented behavior
Identity	Email and password login, Argon2id verification, lockout tracking, encrypted sessions and logout
Governance	User creation, account disablement, role assignment and revocation with anti-self-escalation protection
Device trust	Device registration and administrator-controlled TRUSTED, COMPLIANT, UNTRUSTED or COMPROMISED posture
Protected resources	Resource ownership, sensitivity, required role, risk level, active state and approval requirement
Decisioning	Identity, role, device, resource, temporal and risk evaluation producing ALLOW, DENY, STEP_UP_AUTHENTICATION or REQUIRE_APPROVAL
Audit	Severity, actor, action, result, correlation ID and scrubbed metadata stored as security events

3 Stakeholders and user classes

User class	Goals	Key restrictions
Employee	Sign in, register or inspect devices, request access and understand decisions	Can view only permitted personal data and cannot bypass policy
Resource Owner	Manage owned applications and decide pending approvals	Cannot approve own access request
Security	Manage users, roles, device posture, policies and	Cannot elevate own roles through the

User class	Goals	Key restrictions
Administrator	security status	protected role-management flow
Auditor	Inspect events, decisions and exported evidence	Read-only access to operational data
System Administrator	Perform highest-level governance operations	All actions remain auditable

4 Functional requirements

ID	Name	Requirement
FR-01	User authentication	The system shall authenticate an active user by email and Argon2id-verified password and create a protected session after valid credentials.
FR-02	Login abuse control	The system shall record failed login attempts, enforce temporary account lockout after the configured threshold and rate-limit repeated authentication attempts.
FR-03	Session termination	The system shall invalidate the user session on logout and prevent reuse of the terminated session.
FR-04	User lifecycle	Authorized administrators shall list users, create user accounts and disable an account immediately.
FR-05	Role governance	Authorized administrators shall assign and revoke roles; the system shall prevent protected self-privilege escalation.
FR-06	Server-side authorization	Every protected API operation shall validate the authenticated session and required role or permission on the server.
FR-07	Device registration	An authenticated user shall register a device with name and optional operating-system and browser attributes.
FR-08	Device posture administration	Authorized administrators shall update device status, managed state, compliance state and trust score.
FR-09	Resource registry	Resource owners or administrators shall create and manage internal application records including owner, sensitivity, required role, risk level and approval flag.
FR-10	Resource policy management	Authorized users shall create, update and delete policies containing role, maximum risk, time, day and managed-device constraints.
FR-11	Access request submission	An employee shall submit a reasoned access request for a selected resource and owned device.
FR-12	Context validation	The system shall reject requests involving inactive users or resources, unknown entities, unauthorized devices or prohibited role combinations.
FR-13	Risk assessment	The system shall calculate a score from 0 to 100, classify its level and persist human-readable contributing factors.
FR-14	Dynamic policy evaluation	The system shall evaluate identity, role, device, resource, temporal and risk constraints for every access request.
FR-15	Decision persistence	The system shall persist exactly one decision and one risk assessment for each evaluated access request.
FR-16	Approval routing	If policy or resource configuration requires approval, the system shall place the request in a pending state for its resource owner.

ID	Name	Requirement
FR-17	Approval decision	An authorized resource owner shall approve, reject or request additional authentication with a recorded reason.
FR-18	Segregation of duties	The system shall reject and audit any attempt by a requester to approve their own request.
FR-19	Audit inspection	An auditor or authorized administrator shall filter and inspect security events with actor, action, result, severity, time and correlation data.
FR-20	Operational dashboards	The system shall present role-appropriate summaries for employees, resource owners, administrators and auditors.

5 External interface requirements

5.1 User interface

The interface shall provide a responsive login page and separate employee, owner, administrator and auditor dashboards. Security decisions shall use unambiguous text and status styling and shall expose the decision reason and risk factors without disclosing secrets.

5.2 API interface

Endpoint group	Responsibility
/api/auth/login and /logout	Create or terminate an authenticated session
/api/auth/me	Return the current safe user context
/api/users and /api/users/{id}	List, create, inspect or disable users
/api/users/{id}/roles	Assign or revoke roles
/api/devices and /api/devices/{id}	Register, list and administer devices
/api/resources and /api/resources/{id}	Register, list and manage protected applications
/api/policies and /api/policies/{id}	Create, modify or delete resource policies
/api/access/requests	Submit and list access requests
/api/approvals and /api/approvals/{id}	List and decide approval work
/api/audit	Query audit evidence
/api/stats/admin	Return security-administration metrics

5.3 Communication and validation

Client and API communication shall use HTTPS in non-local environments. JSON request bodies shall be parsed safely and validated with explicit runtime schemas. Malformed input shall return a client error without stack traces or secret values.

6 Data requirements

6.1 Logical entities

Entity	Purpose	Important integrity rule
User	Identity profile and account state	Email is unique and password hash is never returned
Role Permission UserRole	RBAC governance	A user-role pair and role permission are unique
Device	Endpoint posture	Each device belongs to one user
Resource ResourcePolicy	Protected application and constraints	Resource name is unique and policies cascade with resource deletion
AccessRequest	Requested access context	References one user resource and device
RiskAssessment AccessDecision	Explainability and outcome	Exactly one of each per evaluated request
Approval	Human decision record	References request and approver
Session	Server-verifiable authenticated context	Token is unique and expiration is required
AuditLog	Append-only security evidence	Indexed by time actor action severity and correlation ID

6.2 Data retention and privacy

Production retention periods shall be configured by organizational policy. Password hashes, session tokens and secrets shall not appear in dashboards, logs or exports. Audit metadata shall be scrubbed before persistence. Access to personal and security data shall follow least privilege.

Entity Relationship Diagram

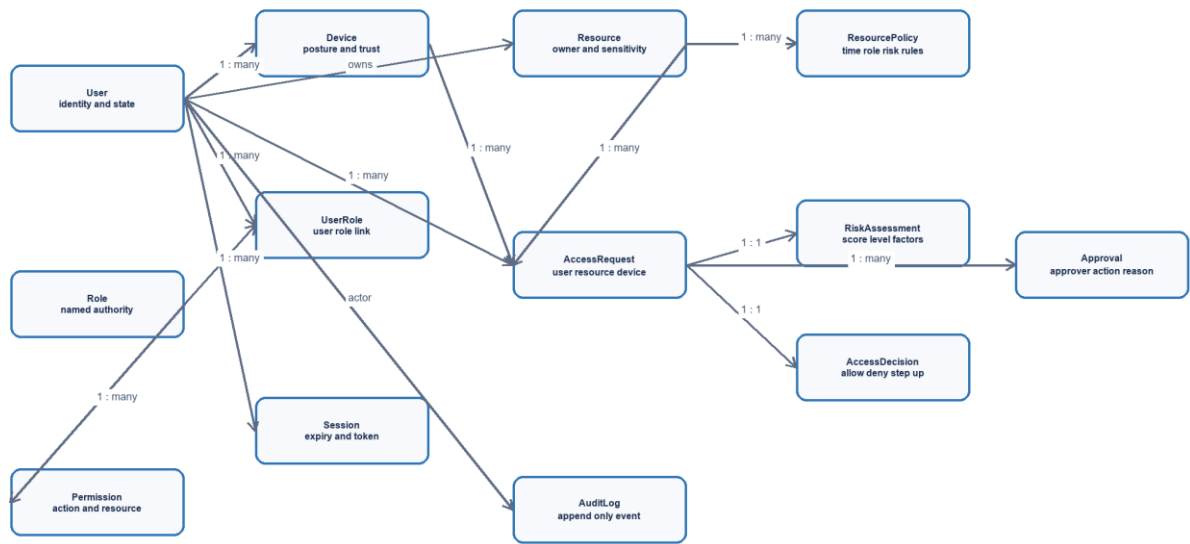


Figure 1 Entity relationship model aligned with the Prisma schema

7 Architecture and design views

7.1 Layered architecture

The design separates presentation, transport and authorization, security decisioning, domain services and persistence. This separation makes policy rules testable and prevents the browser from becoming an authority for access decisions.

Zero Trust Access Portal Architecture

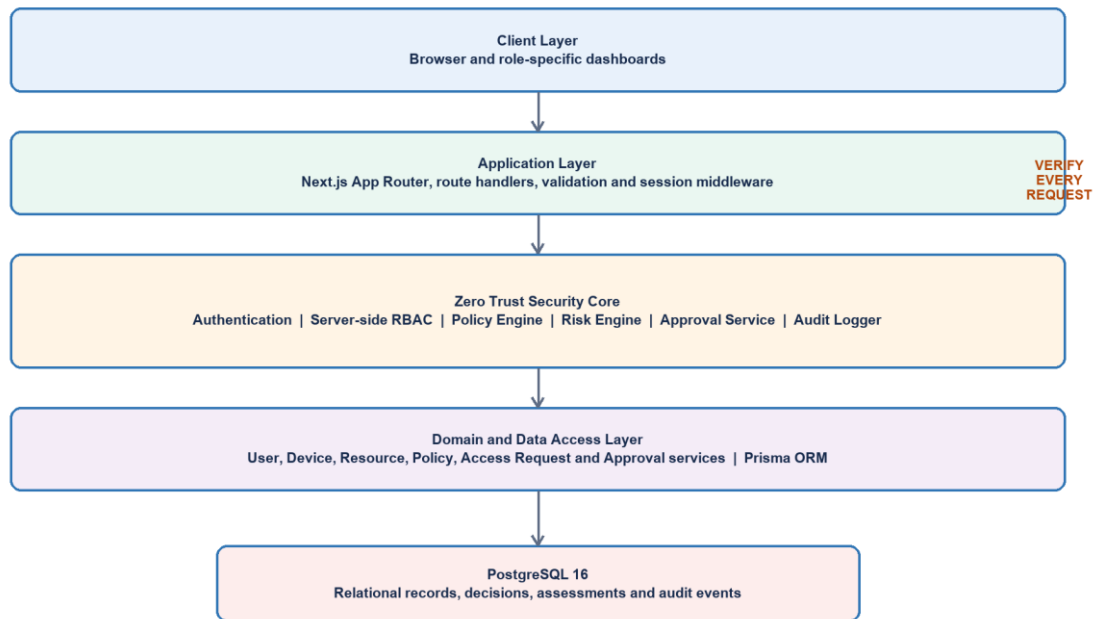


Figure 2 Layered system architecture

7.2 Use case view

Use Case Model

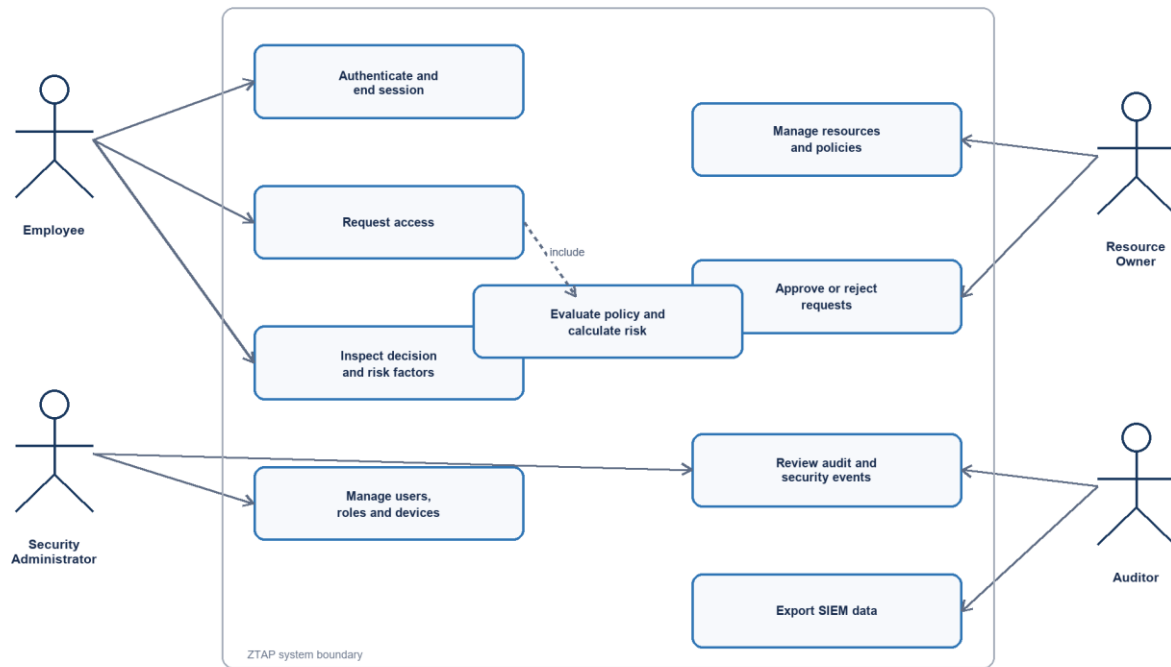


Figure 3 Primary actors and use cases

7.3 Data flow view

Data Flow Diagram Level 1

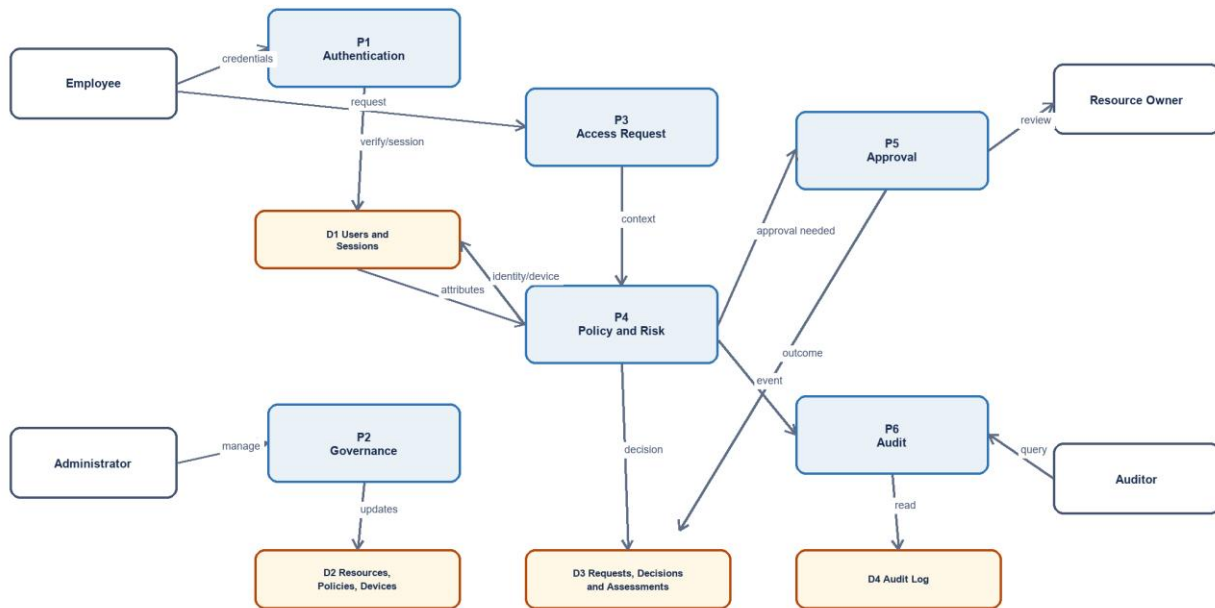


Figure 4 Level 1 data flow across trust boundaries

7.4 Decision sequence

- Authenticate the session and load the safe user context.
- Validate the request, resource and device ownership context.
- Calculate and persist the explainable risk assessment.
- Evaluate identity, role, device, resource, temporal and risk policies.
- Persist the decision and update request status.
- Create an approval path when required and write correlated audit events.
- Return the minimum decision evidence needed by the requesting dashboard.

8 Nonfunctional requirements

ID	Quality	Requirement
NFR-01	Security	Passwords shall use Argon2id; sessions shall use HttpOnly, Secure in production and SameSite protections.
NFR-02	Performance	For normal academic demonstration load, interactive API operations should complete within 2 seconds excluding deployment cold start.
NFR-03	Availability	Container health and restart behavior shall allow the application to recover from process failure without corrupting persisted data.
NFR-04	Reliability	Access decisions and risk assessments shall be transactionally consistent with their access request.
NFR-05	Auditability	Security-sensitive actions shall produce timestamped, correlated and severity-classified audit events.

ID	Quality	Requirement
NFR-06	Maintainability	Security engines and domain services shall remain modular, typed and covered by automated tests.
NFR-07	Usability	Role dashboards shall be responsive, keyboard operable and show clear success, error and empty states.
NFR-08	Portability	The application shall run locally and in Docker; Kubernetes manifests shall use non-root execution and resource constraints.
NFR-09	Scalability	List endpoints shall support pagination and database indexes shall cover frequent identity, status and audit queries.
NFR-10	Observability	Errors and security events shall be diagnosable through structured application and audit data without leaking secrets.

9 Security and privacy requirements

Control area	Required control
Authentication	Credential verification, failed-attempt handling, lockout and secure session lifecycle
Authorization	Default-deny server-side checks and no trust in client-supplied role state
Input security	Schema validation, parameterized ORM access and safe malformed-JSON handling
Separation of duties	Block self-approval and protected self-role modification
Device security	Compromised devices cause denial; managed-device rules are policy enforceable
Data protection	No password hash or session secret in API payloads; secrets supplied through environment configuration
Audit protection	No user-facing mutation route for audit records; metadata is scrubbed
Deployment	Non-root container, dropped Linux capabilities, resource limits and isolated database network
Security headers	Apply browser security headers and production HTTPS controls

10 Verification and acceptance

Test level	Evidence	Acceptance condition
Unit	Password, risk and policy engine tests	All deterministic rules and boundary cases pass
Integration	RBAC and privilege-escalation tests	Unauthorized operations are rejected and audited
Fuzz	Malicious and malformed input suite	Application handles payloads without unsafe execution or secret disclosure
End to end	Browser authentication and role journeys	Critical user journeys complete with expected decisions
Build	Production compilation	Type checking and optimized application build succeed
Demonstration	Role-based demonstration script	Evaluator can reproduce allow deny approval and audit scenarios

10.1 Definition of done

- Acceptance criteria pass and code is reviewed.
- Authorization and negative-path tests exist for protected behavior.
- No known critical or high-severity defect remains open.
- Relevant audit event and error behavior are verified.
- Documentation and backlog traceability are updated.
- The item is deployed or demonstrable in the agreed environment.

11 Requirements traceability

Requirement	Capability	Implementation area	Backlog	Verification
FR-01 FR-02 FR-03	Authentication	Auth routes password and session modules	US-01 US-02	Unit and E2E
FR-04 FR-05 FR-06	Governance and RBAC	User service authorization middleware	US-03 US-04	Integration
FR-07 FR-08	Device trust	Device service and device routes	US-05 US-15	Unit and integration
FR-09 FR-10	Resource and policy	Resource and policy services	US-06 US-14	API integration
FR-11 to FR-16	Access decisioning	Access request policy and risk engines	US-07 US-08 US-09	Unit integration E2E
FR-17 FR-18	Approval workflow	Approval service and approval routes	US-10 US-16	Integration
FR-19	Audit	AuditLogger and audit route	US-11 US-20	Integration and export
FR-20	Dashboards	Role dashboard pages	US-12 US-13	E2E

12 Constraints assumptions and risks

Type	Statement	Response
Constraint	The baseline uses a single application and PostgreSQL database.	Preserve modular services so external policy or identity systems can be added later.
Assumption	A resource has one accountable owner and users select a registered device.	Validate ownership and require administrative correction of inconsistent data.
Assumption	Server time is trustworthy for temporal policies.	Use synchronized infrastructure time in deployed environments.
Risk	Academic seed credentials may be mistaken for production credentials.	Label them as demonstration-only and replace all secrets before deployment.
Risk	Simulated posture is weaker than hardware attestation.	Treat device posture as demonstrative and document future MDM or attestation integration.
Risk	An append-only application API does not alone prevent direct database modification.	Use restricted database roles and external log forwarding in production.

13 Glossary

Term	Meaning
------	---------

Term	Meaning
Zero Trust	A security model that continuously verifies each request instead of trusting network location.
RBAC	Role-based access control that maps roles to permitted operations.
Risk score	A bounded numeric assessment with stored contributing factors.
Step-up authentication	A decision requiring stronger verification before access can continue.
Resource	An internal application or protected service registered in the portal.
Policy	Constraints governing role device time day and acceptable risk for a resource.
SIEM	Security information and event management platform consuming structured security events.
Correlation ID	Identifier linking related operations and audit evidence across a request flow.

Approval

This version is suitable as the requirements baseline for Jira backlog reconstruction, two-sprint planning and final project reporting. Changes to scope should be reflected in both this document and the linked backlog.

Role	Name	Signature	Date
Project supervisor			
Product owner			
Development representative			